

入门

Black Duck SCA 2026.7.0

内容

1. 关于 Black Duck.....3

2. 登录到 Black Duck.....5

3. 扫描您的代码.....7

4. 查看材料清单 (BOM).....8

1. 关于 Black Duck

Black Duck 提供全面的服务和工具套件，为客户的安全之旅提供支持。从刚开始接触安全领域的客户，到正在加强其现有计划的客户，Black Duck 都可以提供成功所需的专业知识、技能和产品。



什么是 Black Duck SCA？

Black Duck SCA 是一种软件构成分析 (SCA) 解决方案，可帮助组织识别、跟踪和管理其代码库中的开源组件。它提供自动化许可证合规、安全漏洞检测和风险评估，帮助团队确保其软件的安全性和完整性。

关键功能

- 开源管理：识别并跟踪项目中的开源组件。
- 漏洞检测：使用国家漏洞数据库 (NVD) 和 Black Duck 安全公告 (BDSA) 自动扫描安全漏洞。
- 许可证合规：分析开源许可证，确保符合公司政策。
- 风险评估和策略执行：定义并执行策略，以降低安全、法律和运维风险。

- 软件材料清单 (SBOM) 生成：生成和管理 SBOM，以保持软件依赖关系的透明度。

Black Duck SCA 如何工作？

- 扫描您的代码：使用 Black Duck 扫描工具（Detect、集成或 API）分析您的代码库。
- 识别组件： Black Duck 将您的代码依赖关系映射到其 KnowledgeBase (KB) 中的已知开源库。
- 评估风险： Black Duck 会检查安全漏洞、许可证问题和策略违反。
- 采取行动：查看报告、确定风险优先级、应用修复并生成 SBOM 以确保合规。

如何开始？

1. 设置一个帐户：登录您的 Black Duck 实例或云托管环境。
2. 运行第一次扫描：分析样本项目并查看发现结果。
3. 查看结果：在 UI 中发现漏洞、许可证风险和策略违规。

开始探索 Black Duck SCA

- 如何使用 Detect 执行扫描
- 了解漏洞报告
- 管理策略违规
- 生成 SBOM

后续步骤

熟悉基础知识后，请使用以下社区资源深入了解 Black Duck 的高级功能和技术配置：

- 浏览界面
- 使用扫描结果
- Black Duck 技术介绍
- 了解更多：访问文档和培训资源。

2. 登录到 Black Duck

要访问 Black Duck SCA，您需要通过浏览器登录。登录后，您将有权访问项目数据，包括可能仅限于团队和组织访问的项目。

注: 您必须拥有有效的登录凭据。如果没有用户名或密码，请联系 Black Duck 管理员。

登录选项

取决于您的组织如何配置身份验证，您可以使用以下方式登录：

- 本地 Black Duck 凭据：由管理员创建的用户名和密码。
- LDAP 凭据：组织的目录服务登录（如果已启用 LDAP）。
- 基于 SAML 的单点登录 (SSO)：您可能会被引导到公司的登录提供商处（如果已配置 SAML）。

注: 如果启用了多因素身份验证 (MFA)，它只适用于使用本地凭据登录的用户。通过 SAML 或 LDAP 进行身份验证的用户不会收到 MFA 提示。

如果您不确定哪种方法适用于您，请与您的管理员联系，以获取指导。

登录步骤

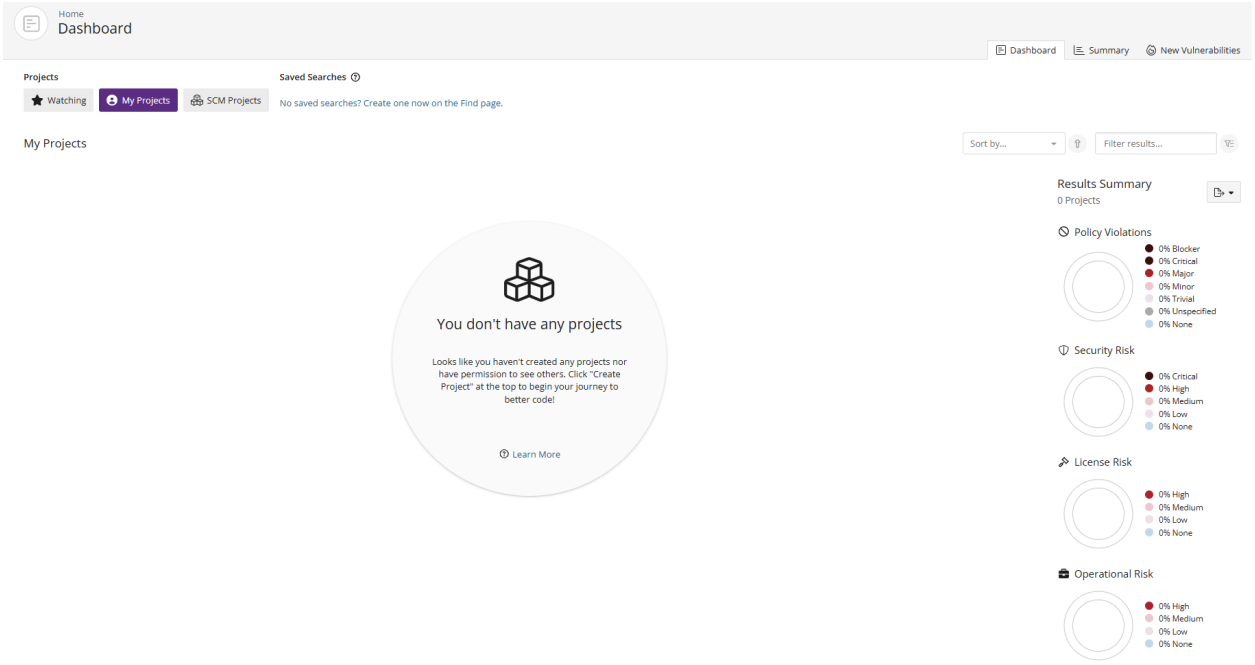
1. 打开浏览器，导航到系统管理员提供的 Black Duck URL。该 URL 通常采用以下格式：

   ```
   https://<your-black-duck-server-hostname>
   ```

2. 输入用户名和密码。
   - 密码区分大小写。
   - 如果这是您第一次登录，或密码不符合系统的安全要求，系统会提示您更改密码。按照屏幕上的密码规则完成更新。
3. 单击登录。
4. 如果您的实例已启用 MFA，在首次登录时，您会收到对其进行配置的提示：
   - 会显示一个二维码。
   - 使用受支持的身份验证应用程序（如 Google Authenticator）扫描二维码。
   - 输入应用程序中的 6 位数字代码，完成设置。

登录后

第一次登录时，您将进入空的仪表板。



要在仪表板上填充数据，需要扫描代码并将其映射到项目版本。本指南的下一部分将涵盖这些步骤。

默认情况下，仪表板显示：

- 我的项目：您创建或被分配的项目。
- 观察：您标记为要监控的项目或组件。

对于您关注的特定项目、版本或组件，您还可以通过保存对它们搜索，创建自定义仪表板。保存的搜索将显示在仪表板上，以便快速访问。

3. 扫描您的代码

扫描是 Black Duck SCA 识别代码库中开源组件、许可证和已知漏洞的核心方法。运行扫描时，Black Duck SCA 会分析您的项目文件并生成一份全面的材料清单 (BOM)，帮助您保持合规、安全和知情。

Black Duck SCA 扫描有哪些作用？

Black Duck 扫描您的代码库，以：

- 识别开源组件及其版本
- 使用国家漏洞数据库 (NVD) 和 Black Duck 安全公告 (BDSA) 等来源检测已知的安全漏洞
- 评估许可证风险和合规性
- 生成用于审计和报告的 BOM
- 根据您组织的风险承受能力执行自定义策略

扫描可以在开发过程中、CI/CD 管道中触发，也可手动触发，具体取决于您集成 Black Duck SCA 的方式。

可用的扫描工具

Black Duck 提供各种工具，以适应不同的环境和工作流程：

- SCM 接入用户界面

  使用 SCM 接入用户界面以实现简化的设置过程，目前仅支持 GitHub.com。此界面简化了集成并帮助您快速接入项目。有关详细说明，请参阅 GitHub Black Duck 集成文档。

- 操作集成

  对于其他 SCM 平台，操作集成提供了灵活选项，可将 Black Duck 纳入您现有的工作流程。快速入门指南（例如 GitLab SCA 快速入门指南）可协助无缝设置扫描。

- Detect CLI

  Black Duck Detect CLI 为高级用户提供了一个功能强大且可定制的扫描工具，用于扫描源代码、二进制文件和容器。它支持集成到 CI/CD 管道中，并提供适用于 Windows 和 Linux 环境的命令（Bash/PowerShell 指南）。

- Detect Desktop

  Detect Desktop 提供了用户友好的桌面应用程序，使用户无需命令行交互即可轻松扫描项目。

- Code Sight IDE

  Code Sight 可直接集成到您的开发环境中，以提供实时扫描和漏洞洞察，帮助开发人员在编码过程中识别并解决问题。

注：某些功能可能需要特定的许可证或配置。如果您不确定您的环境中可以使用哪些扫描工具，请联系您的管理员。

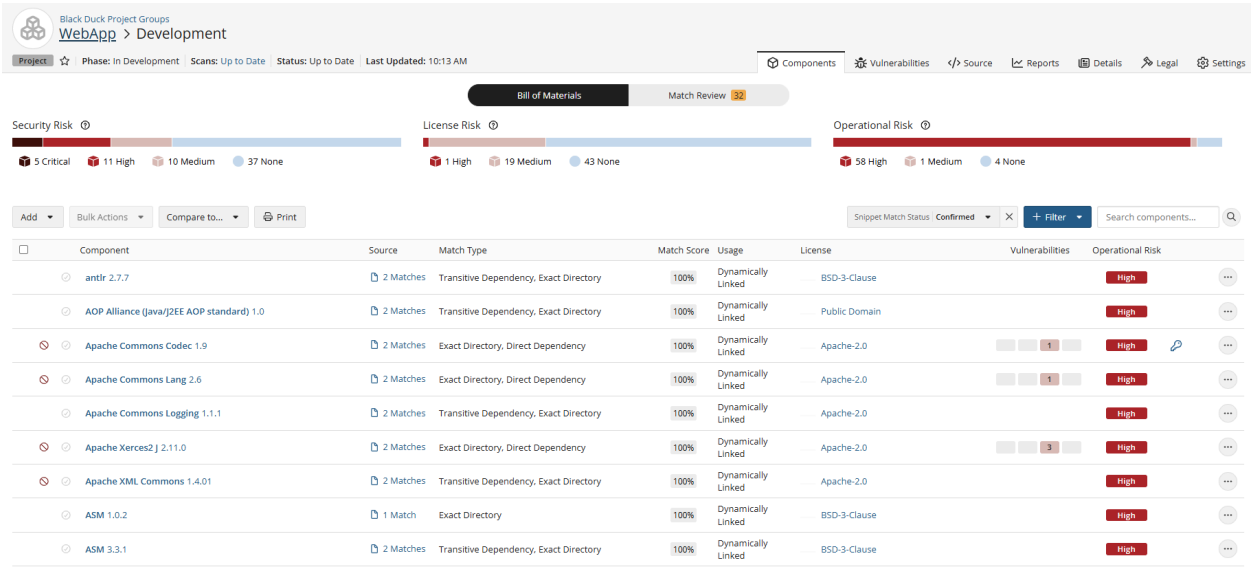
4. 查看材料清单 (BOM)

扫描代码库并将结果映射到项目版本后，Black Duck 会自动生成材料清单 (BOM)。BOM 会列出该项目版本中检测到的所有开源组件，以及许可证、漏洞和策略状态等相关数据。

BOM 让您可以在一个核心视图中了解软件所包含的内容，以及是否需要处理任何风险或合规问题。

如何查看 BOM

1. 登录 Black Duck SCA。
2. 在仪表板上，使用正在关注或我的项目选项卡选择项目。
3. 在项目页面上，选择要查看的版本。这将带您进入组件选项卡，其中将显示 BOM。



了解 BOM 视图

- BOM 会显示在所选项目版本中找到的所有开源组件。
- 默认情况下，它显示扁平视图，即在单一列表中显示所有组件（无论将它们引入代码库的方法是什么）。
- 每个组件条目都包含重要的详细信息，例如组件的名称和版本、匹配类型、许可证，以及安全和运维风险。单击此处了解有关这些组件特征的更多信息。

您可以在 BOM 中进行排序、过滤和搜索，以关注存在高风险或策略违规的组件。

在 BOM 中可以进行的操作

- 单击组件将打开滑出面板，其中包含更多详细信息，包括：
  - 漏洞
  - 许可证
  - 来源 ID（如 PURL、CPE）
  - 其他详细信息，如描述和批准状态
- 如果有适当的权限，您可以直接从 BOM 应用策略覆盖或修复操作。

- 使用 SPDX 或 CycloneDX 等受支持的格式生成 SBOM 报告。

深入探讨

- 要探索 BOM 的用途，请参阅 Black Duck 文档中的项目版本 BOM。
- 如需帮助解读漏洞，请参阅管理安全风险。
- 如需了解如何设置策略，请参阅管理策略。